

Universidad Mayor de San Andrés
Facultad de Ciencias Puras y Naturales
Carrera de Informática



INFORME PENTESTING

Semestre I/2026

Estudiante: Riveros Vera Angeles Sarai

Materia: Taller Técnico Superior

Docente: Lic. Brigida Alexandra Carvajal Blanco

Fecha: 19 de Mayo de 2026

Versión 1.0

La Paz - Bolivia

1. Resumen ejecutivo

El presente informe describe el proceso de evaluación de seguridad realizado sobre el sistema web “Pet Spa V1”, desarrollado por el estudiante Victor Manuel Quito Chavez.

La evaluación tuvo como objetivo verificar el cumplimiento de controles básicos de seguridad relacionados con autenticación, validación de formularios, gestión de sesiones y control de acceso.

La revisión fue realizada exclusivamente mediante el análisis de una demostración en video proporcionada por el estudiante desarrollador, sin acceso directo al código fuente, servidor, base de datos ni entorno de ejecución. Debido a ello, las observaciones y conclusiones presentadas en este informe se basan únicamente en las funcionalidades evidenciadas durante la demostración audiovisual.

Durante la evaluación se evidenció la implementación de mecanismos de seguridad como autenticación multifactor (2FA), hashing seguro de contraseñas, activación de cuentas mediante correo electrónico, auditoría explícita de acciones y autenticación diferenciada según roles de usuario.

2. Alcance de la prueba

Elemento	Descripción
Sistema objetivo	Sistema Web Spa de Mascotas
Tipo de sistema	Aplicación web
Tecnologías identificadas	PostgreSQL, pgAdmin, Laravel
Módulos evaluados	Login, registro de usuarios, gestión de sesiones y control de acceso
Funcionalidades revisadas	Activación por correo, bloqueo de cuentas, hashing de contraseñas, auditoría
Periodo de evaluación	12/05/26 al 19/05/26
Responsable del sistema	Quito Chavez Victor Manuel
Evaluator	Riveros Vera Angeles Sarai
Evidencia analizada	https://www.youtube.com/watch?v=EJ8NmGSTEQ4

3. Metodología utilizada

La metodología utilizada aplicada estuvo basada en observación funcional del sistema mediante una grabación de video proporcionada por el estudiante desarrollador. No se ejecutaron herramientas automatizadas de escaneo, explotación de vulnerabilidades ni pruebas directas sobre infraestructura real.

3.1. Recolección de información

Durante la demostración se identificaron los siguientes controles de seguridad:

Control observado	Estado
Registro libre de clientes	Implementado
Registro manual de empleados	Implementado
Activación por correo electrónico	Implementado
Seguridad de contraseñas	Implementado
Email de Activación	Implementado
Expiración de enlaces de activación	Implementado
Bloqueo por intentos fallidos	Implementado
Hashing seguro de contraseñas	Implementado
Auditoría	Implementado
Borrado lógico	Implementado
Autenticación 2FA	Implementado
Inicio de sesión/continuar con Google	Implementado

3.2. Observaciones adicionales

- Se evidenció un sistema de autenticación diferenciado para clientes y personal administrativo.
- La auditoría de acciones fue mostrada explícitamente durante la demostración. Además de contar con un botón para actualizar las acciones realizadas evitando que el sistema colapse.
- El sistema utiliza correos de prueba para validar funcionalidades relacionadas con activación y autenticación.
- Se observaron múltiples mecanismos de seguridad correctamente integrados en el sistema.
- No fue posible verificar configuraciones internas del servidor o políticas avanzadas de seguridad debido a las limitaciones de acceso.

4. Hallazgos encontrados

Código	Observación	Módulo	Riesgo	Descripción	Recomendación
V-01	Uso de correos de prueba para validaciones	Activación	Bajo	Durante la demostración se utilizaron correos temporales o de prueba para verificar funcionalidades del sistema	Validar funcionamiento completo utilizando correos reales en entorno productivo
V-02	Validación limitada mediante video	General	Bajo	Algunas configuraciones internas de seguridad no pudieron verificarse directamente	Realizar pruebas técnicas directas en futuras evaluaciones
V-03	Configuración interna no verificable	Infraestructura	Bajo	No fue posible comprobar configuraciones del servidor, HTTPS o protección avanzada de sesiones	Realizar auditoría técnica en entorno real

Las vulnerabilidades encontradas fueron clasificadas según su impacto.

Nivel	Descripción
Alto	Vulnerabilidades que afectan la seguridad crítica
Medio	Riesgos explotables bajo ciertas condiciones
Bajo	Riesgo de seguridad baja

5. Evidencias

Las evidencias obtenidas corresponden únicamente a capturas extraídas de la demostración en video proporcionada por el estudiante que desarrolló el sistema.

Durante la evaluación se observaron las siguientes funcionalidades:

- Inicio de sesión

Bienvenido a PetSpa V1

Gestiona reservas, servicios y experiencia de clientes en un solo ...

[Soy Cliente — Entrar](#)[Registrarse \(Cliente\)](#)

[Acceso Personal \(Empleados\)](#)



PETSPA V1

Acceso administrativo

Credenciales (Google 2FA en el siguiente paso).

Correo

admin@petspa.local

Contraseña

••••••••

Continuar



PETSPA V1

Iniciar sesión

Accede a tu cuenta de cliente.

Correo

manuelworkbo@gmail.com

Contraseña

password123

Entrar

o continúa con

 Continuar Con Google

¿No tienes cuenta?

[Regístrate](#)

¿Personal del spa?

[Entrar aquí](#)

- Autenticación de 2F



PETSPA V1

Código de verificación

Introduce el código de 6 dígitos desde tu app Authenticator.

Código (6 dígitos)

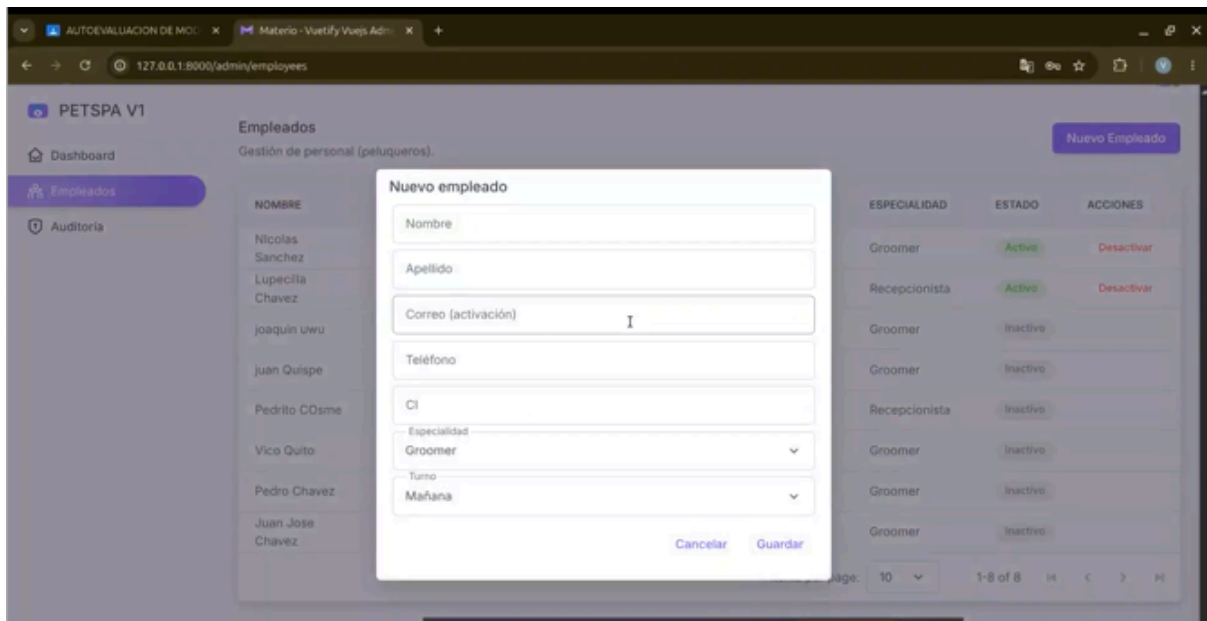
Verificar Y Entrar

Volver

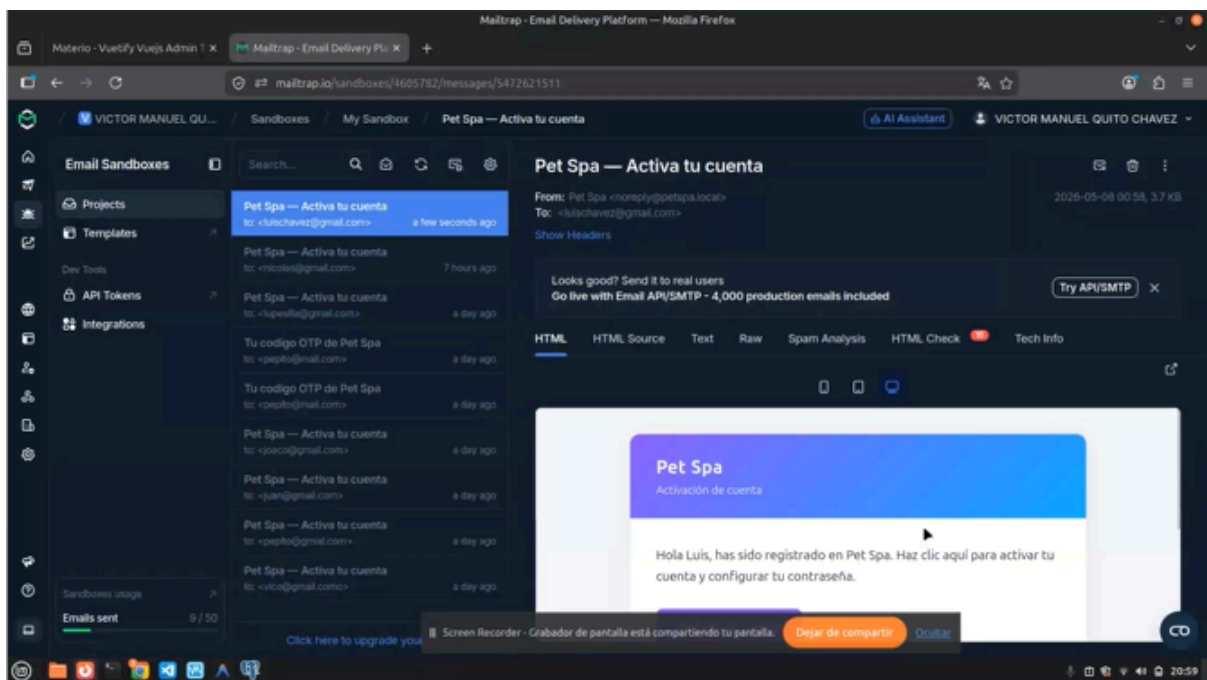
- Password hashado

```
password
character varying (255)
$2y$12$.3fdmUEXfLKq.xsWSUYbPOYp8jsSRkY8lh9Yfm/DgN!
$2y$12$pFfSTqaCfO6cgXSZMPFguuziwp8muOWCQcojteKID
$2y$12$eA6H74NjogS5Evn3RMyB/ex3US8ndbrWZV3etmx2T
$2y$12$1wzFwY62l285G1eVXYuVYhQv45DlR2hBNhB4dN
```

- Registro de usuarios



- Activación de cuentas mediante correo electrónico



- Bloqueo de cuentas tras 5 intentos fallidos.

- Registro de auditoría

Auditoría y trazabilidad

Registros recientes desde `storage/logs/audit.log` (ventana limitada en memoria). [Refrescar](#)

EVENTO	USUARIO	FECHA	IP	USER-AGENT
Otro admin.dashboard.metrics	1/admin	8/5/26, 0:53:25	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.2fa.challenge	guest/anonymous	8/5/26, 0:53:25	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.login	guest/anonymous	8/5/26, 0:53:10	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro admin.employees.index	1/admin	8/5/26, 0:50:41	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro admin.dashboard.metrics	1/admin	8/5/26, 0:48:52	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.2fa.challenge	guest/anonymous	8/5/26, 0:48:52	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Acceso admin.auth.login	guest/anonymous	8/5/26, 0:48:33	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro admin.dashboard	1/admin	8/5/26, 0:47:24	127.0.0.1	Mozilla/5.0 (X11; Linux x86_64) ...
Otro				Mozilla/5.0 (X11; Linux x86_64) ...

- Borrado lógico

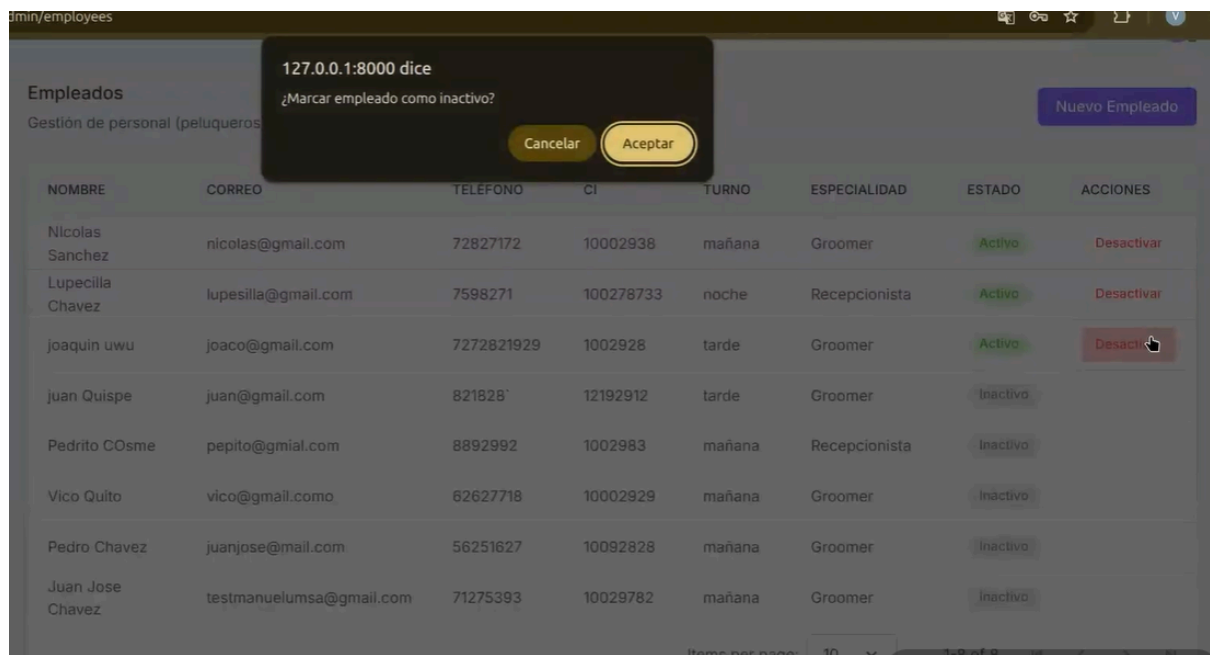
PETSPA V1

Dashboard Empleados Auditoria

Empleados
Gestión de personal (peluqueros). [Nuevo Empleado](#)

NOMBRE	CORREO	TELÉFONO	CI	TURNO	ESPECIALIDAD	ESTADO	ACCIONES
Nicolas Sanchez	nicolas@gmail.com	72827172	10002938	mañana	Groomer	Activo	Desactivar
Lupecilla Chavez	lupecilla@gmail.com	7598271	100278733	noche	Recepcionista	Activo	Desactivar
Joaquin uwu	joaco@gmail.com	7272821929	1002928	tarde	Groomer	Activo	Desactivar
Juan QJispe	juan@gmail.com	821828	12192912	tarde	Groomer	Inactivo	
Pedrito COsme	pepito@gmail.com	8892992	1002983	mañana	Recepcionista	Inactivo	
Vico Quito	vico@gmail.com	62627718	10002929	mañana	Groomer	Inactivo	
Pedro Chavez	juanjose@mail.com	56251627	10092828	mañana	Groomer	Inactivo	
Juan Jose Chavez	testmanuelumsa@gmail.com	71275393	10029782	mañana	Groomer	Inactivo	

Items per page: 10 1-8 of 8



6. Recomendaciones generales

- Mantener actualizadas las políticas de seguridad implementadas.
- Continuar utilizando hashing seguro de contraseñas.
- Aplicar HTTPS obligatorio en todo el sistema.
- Verificar periódicamente permisos y roles de usuario.
- Implementar monitoreo continuo de auditoría.
- Validar seguridad de correos electrónicos utilizados en producción.
- Mantener Laravel, PostgreSQL y dependencias actualizadas.
- Realizar pruebas periódicas de penetración y revisiones de vulnerabilidades.
- Implementar políticas de expiración automática de sesiones.
- Mantener respaldos periódicos de la base de datos y archivos importantes.

7. Conclusiones

La evaluación realizada sobre el sistema web “Pet Spa V1” permitió evidenciar la implementación de múltiples mecanismos de seguridad orientados a proteger la autenticación, gestión de usuarios y control de accesos.

Durante la demostración se observaron controles importantes como autenticación multifactor (2FA), hashing seguro de contraseñas, auditoría explícita de acciones, bloqueo de intentos fallidos e integración con autenticación mediante Google, lo cual fortalece significativamente la seguridad general del sistema y cumpliendo así con todos los parámetros establecidos.

Debido a que la revisión fue realizada únicamente mediante una demostración en video, no fue posible validar completamente configuraciones internas ni ejecutar pruebas técnicas directas sobre la infraestructura real. Sin embargo, las

funcionalidades observadas evidencian una implementación adecuada de controles básicos y avanzados de seguridad.

Se recomienda realizar futuras evaluaciones técnicas en un entorno controlado para verificar de forma más profunda los mecanismos internos de protección y fortalecer continuamente la seguridad del sistema.